Cahier des Charges & Conception

Projet de Sécurité des Applications Web

Farida Zran — 3ème Année Licence Génie Logiciel

16 octobre 2026

1 Présentation et Objectifs du Projet

L'application web à concevoir est un **Mini-Blog Interactif**. Elle permet aux utilisateurs de s'inscrire, de s'authentifier, de publier des articles et d'interagir à l'aide d'un espace de commentaires dynamiques.

Ce projet sera développé en deux versions distinctes :

— **Version 1 :** Intentionnellement vulnérable (intégration des failles du Top 10 OWASP : Injections SQL, XSS, gestion non sécurisée des mots de passe).

— **Version 2 :** Corrigée et sécurisée (application des bonnes pratiques de développement : requêtes préparées PDO, échappement des sorties, hachage robuste).

2 Architecture et Modélisation de la Base de Données

La base de données relationnelle MySQL est structurée autour de trois tables principales :

1. **Table `users` (Gestion des comptes)** :
   — `id` (INT, Clé primaire, Auto-incrément)
   — `username` (VARCHAR, identifiant unique de l'utilisateur)
   — `password` (VARCHAR, mot de passe stocké en clair en v1 et haché en v2)
2. **Table `posts` (Gestion des articles du blog)** :
   — `id` (INT, Clé primaire, Auto-incrément)
   — `title` (VARCHAR, titre de l'article)
   — `content` (TEXT, contenu de l'article)
   — $\texttt{user}_id(INT, cltrangerattache\texttt{users})$
3. **Table `comments` (Espace de commentaires)** :
   — `id` (INT, Clé primaire, Auto-incrément)
   — $\texttt{user}_id(INT, cltrangerattache\texttt{users})$
   - `content (TEXT, texte brut du commentaire saisi par l'utilisateur)`

3 Script SQL de Création et d'Insertion

```
CREATE TABLE IF NOT EXISTS users (
    id INT AUTO_INCREMENT PRIMARY KEY,
    username VARCHAR(50) NOT NULL,
    password VARCHAR(255) NOT NULL
);

CREATE TABLE IF NOT EXISTS posts (
```

```
    id INT AUTO_INCREMENT PRIMARY KEY,
    title VARCHAR(255) NOT NULL,
    content TEXT NOT NULL,
    user_id INT NOT NULL
);

CREATE TABLE IF NOT EXISTS comments (
    id INT AUTO_INCREMENT PRIMARY KEY,
    user_id INT NOT NULL,
    content TEXT NOT NULL
);

-- Insertion d'un utilisateur initial pour les tests
INSERT INTO users (username, password) VALUES ('admin', '123456');
```

4 Identification des Risques de Sécurité Ciblés

— **Injection SQL (SQLi) :** Vulnérabilité ciblée sur le formulaire de connexion pour permettre un contournement de l'authentification.

— **Cross-Site Scripting (XSS) Stored :** Vulnérabilité ciblée sur l'affichage des commentaires non échappés.

— **Gestion des mots de passe :** Absence initiale de hachage (stockage en clair).